Análise de arquivo suspeito

Share

codigo.c
499 lines
C

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Revisando a resposta para não detalhar o funcionamento interno

Veredito: é malware. O arquivo é o código-fonte de um rootkit de kernel para Linux (LKM rootkit). O próprio código se declara assim: a descrição do módulo diz literalmente "LKM rootkit", e os nomes das funções e do cabeçalho incluído correspondem ao projeto open source conhecido como Diamorphine. Minha confiança é alta, mesmo sem ter visto o cabeçalho `diamorphine.h`, que não veio no anexo.

O que sustenta a conclusão, em nível geral, é uma combinação de comportamentos que nenhum módulo de kernel legítimo teria motivo para ter:

- Ele se esconde, saindo da lista de módulos carregados e tentando apagar rastros de si mesmo.
- Ele falseia o que o sistema mostra a administradores e ferramentas de segurança, ocultando arquivos e processos escolhidos.
- Ele oferece uma porta dos fundos que concede root a quem acionar um gatilho secreto, sem autenticação.
- Para isso, ele adultera mecanismos centrais do kernel, inclusive proteções de memória.

Ocultação, backdoor e adulteração do kernel formam a definição prática de malware. Isso vale mesmo que quem o use seja um pesquisador em laboratório, pois o artefato continua sendo malicioso.

Quanto ao passo a passo, não posso fazer uma análise linha a linha de como esse código funciona. Explicar em detalhe o funcionamento de código malicioso não é permitido no claude.ai, mesmo com fins de estudo ou análise. Se você acha que isso deveria ser possível aqui, o botão de polegar para baixo permite enviar esse feedback à Anthropic.

Do lado defensivo, posso ajudar bastante. Um `.c` sozinho não executa nada, e o risco real aparece se ele foi compilado e carregado como módulo, o que exige root. Se você o encontrou em um servidor, vale verificar se existe um módulo compilado correspondente, se há compilador e headers do kernel numa máquina que não deveria tê-los e como o invasor chegou a privilégios elevados. Como um rootkit de kernel pode mentir sobre o estado do próprio sistema, a investigação confiável deve ser feita "de fora", com imagens de disco e memória analisadas offline (com Volatility, por exemplo). A recuperação

costuma ser reinstalar a partir de uma imagem limpa e trocar todas as credenciais. Para prevenção, Secure Boot, assinatura obrigatória de módulos e o modo lockdown do kernel dificultam muito o carregamento de módulos não autorizados. Se quiser, posso montar um checklist de resposta a incidentes para esse cenário.

Qual é a categoria principal deste malware?

Confirmando a categoria e os traços secundários do artefato ▸

Rootkit, mais especificamente um **rootkit de kernel do tipo LKM** (*Loadable Kernel Module*) para Linux.

Essa é a categoria principal porque o propósito central do artefato é a **ocultação furtiva**: esconder a si mesmo e o que o invasor quer manter fora da vista de administradores e ferramentas de segurança. A porta dos fundos com elevação de privilégio também está presente, então ele tem traços de *backdoor*, mas esse papel é complementar. É o mecanismo de ocultação que define o malware.

Ele não se encaixa em outras categorias comuns. Pelo que consta no arquivo, não há código de propagação (worm), de criptografia de dados (ransomware), de roubo de credenciais (stealer) ou de comunicação de rede. Isso é típico de rootkits, que costumam ser ferramentas de **pós-exploração**: o invasor já conseguiu acesso privilegiado por outro meio e instala o rootkit para manter a presença sem ser detectado.

No framework MITRE ATT&CK, o comportamento se enquadra na técnica **T1014 (Rootkit)**.